

BUG BOUNTY — Lógica de Puzzles por Fase

Caso #01 — A Senha de Fábrica

Conceito: credenciais padrão de fábrica não trocadas.

Puzzle 1 — Observação/Zoom (Beat 2)

- Tela: foto estática do balcão da pizzaria, com o roteador borrado ao fundo.
- Interação: o jogador arrasta/pinça para dar zoom e mover o enquadramento (crop) até revelar a etiqueta.
- Condição de vitória: aproximar o zoom o suficiente para o texto do modelo (RT-2100X, por exemplo) ficar legível, dentro de um número limitado de "recortes", cada recorte errado gera ruído visual, simulando perda de qualidade.

Puzzle 2 — Pesquisa/OSINT (Beat 3)

- Tela: navegador falso dentro do jogo com uma barra de busca.
- Interação: jogador digita o modelo encontrado; recebe 3–4 resultados de fórum/blog fictício. Só um deles contém a combinação usuário/senha padrão real daquele modelo; os outros são 红 herrings (posts genéricos, propaganda, reclamação sem dado útil).
- Condição de vitória: selecionar o resultado certo e "anotar" a credencial (ela é salva automaticamente no inventário/notebook do jogador).

Puzzle 3 — Login (Beat 4)

- Tela: formulário de login do painel administrativo da pizzaria.
- Interação: jogador arrasta a credencial anotada para os campos usuário/senha.
- Condição de vitória: campos preenchidos corretamente → acesso concedido. Erro → mensagem genérica de "senha incorreta" sem dar dica adicional (reforça que a falha real é não ter trocado a senha, não a dificuldade de adivinhar).

Caso #02 — O Carrinho de Compras Mágico

Conceito: confiança indevida no cliente (preço não validado no servidor).

Puzzle 1 — Reconhecimento (Beat 2)

- Tela: loja fictícia navegável (catálogo com 3 produtos).
- Interação: nenhuma mecânica de erro aqui, é exploração livre para o jogador notar o produto caro (Smart TV).

Puzzle 2 — Inspeccionar/Editar Elemento (Beat 3–4)

- Tela: uma versão simplificada de "inspeccionar elemento" (painel lateral estilo dev-tools, mas com poucos campos, não o HTML real).
- Interação: o jogador navega uma pequena árvore de elementos (ex: produto > preço > valor: 2499) e clica no campo de valor para editá-lo.
- Condição de vitória: alterar o valor (ex: para 0 ou 1) e clicar em "finalizar compra". O jogo confirma o pedido e dispara a notificação de pânico do Marcos (Beat 5) automaticamente.
- Variante de dificuldade: em vez de um campo óbvio, o jogador pode precisar identificar o campo certo entre 2-3 campos similares (nome, estoque, preço), ensinando a ler a estrutura antes de agir.

Caso #03 — O Furo na Ficha (SQL Injection)

Conceito: entrada de busca que mistura dados com comandos lógicos.

Puzzle 1 — Mentoria (Beat 2)

- Não é bem um puzzle de erro/acerto: é uma cutscene interativa em que o "???" explica o conceito com um exemplo visual (uma balança ou "porta lógica" que abre quando a frase é sempre verdadeira). Pode ter 1–2 perguntas de múltipla escolha só para fixar o conceito antes de liberar o próximo puzzle.

Puzzle 2 — Exploit (Beat 4)

- Tela: barra de busca do painel de funcionários do Detran (fictício).
- Interação: o jogador monta a query por blocos (peças arrastáveis tipo "quebra-cabeça de sintaxe"), em vez de digitar código livre, evita ensinar sintaxe real, mas ensina a lógica. Peças disponíveis: nome_da_placa, ' OR ', ' = ', -- (ignorar resto), e peças distratoras (AND, NOT, valores aleatórios).
- Condição de vitória: montar uma combinação que resulte logicamente em "sempre verdadeiro" (ex.: placa = " OR '1'='1' --). O jogo valida a *estrutura lógica* da combinação, não uma string exata, várias combinações corretas devem ser aceitas.
- Falha: combinações incorretas retornam "nenhum resultado encontrado", sem penalidade dura, permitindo tentativa e erro.

Caso #04 — O Vizinho Bisbilhoteiro (IDOR)

Conceito: identificador sequencial sem controle de acesso.

Puzzle 1 — Reconhecimento (Beat 2)

- Tela: "exame" do próprio jogador, com uma barra de endereço falsa mostrando [.../exame/00842](#).
- Interação: jogador percebe (dica textual do jogo) que o número é só um ID incremental.

Puzzle 2 — Busca sistemática (Beat 4)

- Tela: mesma barra de endereço, editável.
- Interação: jogador digita números próximos ao seu ID e "navega". Cada tentativa consome 1 unidade de um medidor de "tempo/risco" (simula que ficar tentando é arriscado/lento).
- Mecânica: para reduzir tentativa por força bruta pura, o jogo pode dar uma pista de intervalo ("os exames dessa semana ficam entre 00800 e 00860") e permitir uma busca binária guiada, o jogador testa um ID, o jogo diz "mais alto" ou "mais baixo" em termos de data do exame.
- Condição de vitória: acertar o ID do Ricardo Alves dentro do limite de tentativas/tempo.

Caso #05 — Fora dos Limites (Path Traversal)

Conceito: navegação para fora de uma pasta pública usando `../`.

Puzzle 1 — Reconhecimento (Beat 2)

- Tela: botão de "baixar wallpaper" no site da desenvolvedora; ao clicar, mostra a URL gerada, com uma pasta visível (</public/wallpapers/img1.png>).

Puzzle 2 — Exploit (Beat 3–4)

- Tela: visualização em árvore de pastas (mini file-explorer), com a pasta pública destacada e pastas "trancadas" ao lado/acima (privadas, marcadas com cadeado).
- Interação: o jogador edita o caminho arrastando/clicando em segmentos `../` para "subir" de nível, ou digita o caminho em um campo com autocomplete guiado (evita digitação livre de comandos reais).
- Condição de vitória: montar um caminho que suba da pasta pública até a pasta interna (<../../interno/lancamento.doc>) e abra o documento com a data de lançamento.
- Falha: caminho errado mostra "pasta não encontrada" (feedback neutro, sem punir tempo).